

Client Dependency Policy & Justification Register

Document ID: DOC-DEP-001

Classification: Official

System: Case Ace v2.0 (Citizens Advice Wandsworth)

Standard Alignment: ISO/IEC 27001:2022 A.8.30 (Outsourced development), ISO/IEC 27701:2019, ISO/IEC 42001:2023

1. Supply Chain & Dependency Policy

Every third-party dependency in the client bundle is a supply chain risk to a system handling Special Category Data (under UK GDPR Article 9) and confidential advice consultations.

Policy Rules:

Absolute Pinning: Every dependency version must be exact (no ranges, no ^, no ~).

Zero Network Calling: Any library that initiates automated telemetry, beacons, background update checks, or external HTTP/WebSocket connections is strictly rejected.

Exclusivity Justification: Each package must be justified by demonstrating that native Web Platform APIs cannot fulfill the functional or accessibility requirement.

Permissive Open Source Licensing: Only approved OSI licenses (MIT, Apache-2.0, BSD-3-Clause, ISC) are permitted.

Continuous SBOM Verification: Software Bill of Materials (SBOM) must be generated and tracked in the evidence/repository.

2. Client Production Dependencies (client/dependencies)

3. Client Build & Development Dependencies (client/devDependencies)

4. Rejection Register (Evaluated & Disallowed Dependencies)

The following dependencies were evaluated and explicitly rejected:

Sentry / Bugsnag / LogRocket: REJECTED. Violates Constraint C1, C2, and C9. Client-side error monitors capture stack traces, console logs, and DOM snapshots which could leak confidential client consultation data to third-party servers.

Google Analytics / Mixpanel / Segment: REJECTED. Violates Constraint C1 and supply chain policy. Automated telemetry and tracking cookies are strictly forbidden.

Google Fonts / Adobe Typekit: REJECTED. Violates CSP and privacy constraints. System fonts and self-hosted fonts are used exclusively.

Axios / Request wrappers: REJECTED. Native fetch API provides all required HTTP capabilities with zero supply chain overhead.

Redux Persist / LocalStorage adapters: REJECTED. Violates Constraint C1 (Zero Non-Volatile Persistence).